먹잇감도 달라졌다… 기업이 가진 'AI 출입증' 훔쳐가는 해커들

일종의 AI 이용권인 'API 키'
탈취한 키로 AI 돌려서 해킹
남은 키는 암시장에 되팔아

공개 플랫폼에 키 정보 노출
기업의 허술한 관리도 문제

해커의 새로운 표적 'API 키'

해커들의 표적이 바뀌고 있다. 고객 개인정보뿐 아니라 기업이 인공지능(AI)을 이용하기 위해 발급받은 'API 키'가 새로운 먹잇감으로 떠올랐다. 훔친 키로 피해 기업의 비용을 쓰면서 AI를 돌려 다른 회사를 공격하고 남은 키는 암시장에 되파는 식이다. AI가 해킹 도구가 되는 것을 넘어 AI '이용권'이 범죄 자산이 되고 있다는 경고가 나온다.

9일 보안업계에 따르면 앤트로픽은 지난달 공개한 위협 인텔리전스 보고서에서 탈취한 API 키와 세션 토큰으로 AI에 접근하는 행위 자체가 일부 범죄집단의 주요 목표가 되고 있다고 밝혔다.

API 키는 기업이 클로드·챗GPT·제미나이 같은 AI 모델을 자사 서비스나 업무 시스템에 연결할 때 쓰는 인증 정보다. 이 키로 AI를 호출하면 요금은 키를 발급받은 기업 계정에 청구된다. 정찰과 취약점 탐색, 악성코드 작성 등을 위해 모델을 반복적으로 호출해야 하는 해커에게는 남의 비용으로 AI를 쓰는 '공짜 티켓'인 셈이다.

앤트로픽은 공격자가 AI 자격 증명을 확보하면 키를 되팔 수 있는 '전리품(loot)'과 공격에 필요한 연산 자원(compute), 정상 이용자 계정 뒤에 숨을 수 있는 '위장 효과(cover)'를 동시에 얻는다고 분석했다.

실제로 해킹조직 샤이니헌터스 연계 공격자들은 침입 과정에서 피해 기업의 AI API 키를 확보하자 자신들의 키 대신 피해 기업 키로 공격 작업을 옮겼다. 다른 공격집단은 탈취한 키만으로 약 한 달간 공격을 이어갔다.

키 자체를 겨냥한 공격도 정교해지고 있다. 앤트로픽이 'GTG-50020'으로 분류한 러시아어권 공격자는 한 AI 업체의 자동 평가용 샌드박스에 악성 지시를 심어 그 안에 저장된 여러 AI 업체의 운영용 API 키를 빼냈다. 이 키를 통해 약 4일간 AI 기업 30여 곳을 상대로 같은 수법을 변형해 공격했고 사전 공개 단계의 클로드 모델에 접근하려 12가지가 넘는 경로를 시험했지만 실패했다. 앤트로픽은 이용된 키가 모두 고객사 환경에서 탈취된 것이며 자사 시스템은 침해되지 않았다고 설명했다.

문제는 키 유출 사건 중 상당수가 고도의 해킹 기술보다 허술한 관리에서 비롯된다는 점이다. 개발자가 공개 깃허브(GitHub) 저장소에 키가 포함된 코드를 올리거나 모바일 앱, 도커(Docker) 컨테이너, 챗봇 소스코드에 인증정보를 남겨두는 사례가 대표적이다. 보안업체 깃가디언(GitGuardian)의 '시크릿 스프롤 현황 2026' 보고서에 따르면 지난해 공개된 깃허브에서 탐지된 AI 서비스 관련 시크릿(API 키·토큰 등 인증정보)은 127만5105개로 전년보다 81% 늘었다. 전체 시크릿은 약 2865만개였다. 클로드 코드(Claude Code)의 도움을 받아 작성한 코드 변경 기록 100건 중 약 3건에서 인증정보가 발견돼 일반 코드(약 1.5건) 대비 두 배에 달했다.

최근 국내 금융권 연쇄 해킹도 '외부 접점' 관리의 중요성을 보여준다. 신한·KB국민·하나은행 사고는 모두 핵심 금융 거래망이 아니라 대출모집인 조회 서비스, 직원용 업무지원 시스템 같은 외부 접점이 통로였다.

이들 사고에서 AI API 키가 유출됐다는 사실은 확인되지 않았지만 기업들이 챗봇과 AI 에이전트를 업무 시스템에 빠르게 연결하는 만큼 이곳에 저장된 AI 인증정보까지 점검해야 한다는 지적이 나온다.

보안 전문가는 "과거에는 API 키가 개발 과정의 기술정보 정도로 취급됐지만 이제는 키 하나로 고성능 AI를 대량 호출하고 내부 시스템과 연결된 에이전트까지 움직일 수 있다"며 "보유한 AI 키를 전수조사해 불필요한 것은 폐기하고, 키별로 권한과 사용 한도를 최소화해 주기적으로 교체해야 한다"고 말했다.

김대기 기자